

WEB VAPT EVIDENCE FILE DOCUMENTATION

07-nikto-scan-findings.png

Field	Details
Project	Enterprise Security Assessment Lab
Module	Sub-Project 1 - Web Application VAPT
Evidence Row	08 - Nikto scanning
Evidence File	07-nikto-scan-findings.png
Result Type	Vulnerability scan output
Prepared For	GitHub portfolio documentation

Document Purpose

This PDF documents one specific evidence file from the Web VAPT evidence table. It embeds the actual screenshot, explains what the screenshot proves, maps it to the methodology, and records professional interpretation, risk, remediation, and redaction guidance for GitHub publication.

1. Embedded Evidence Screenshot

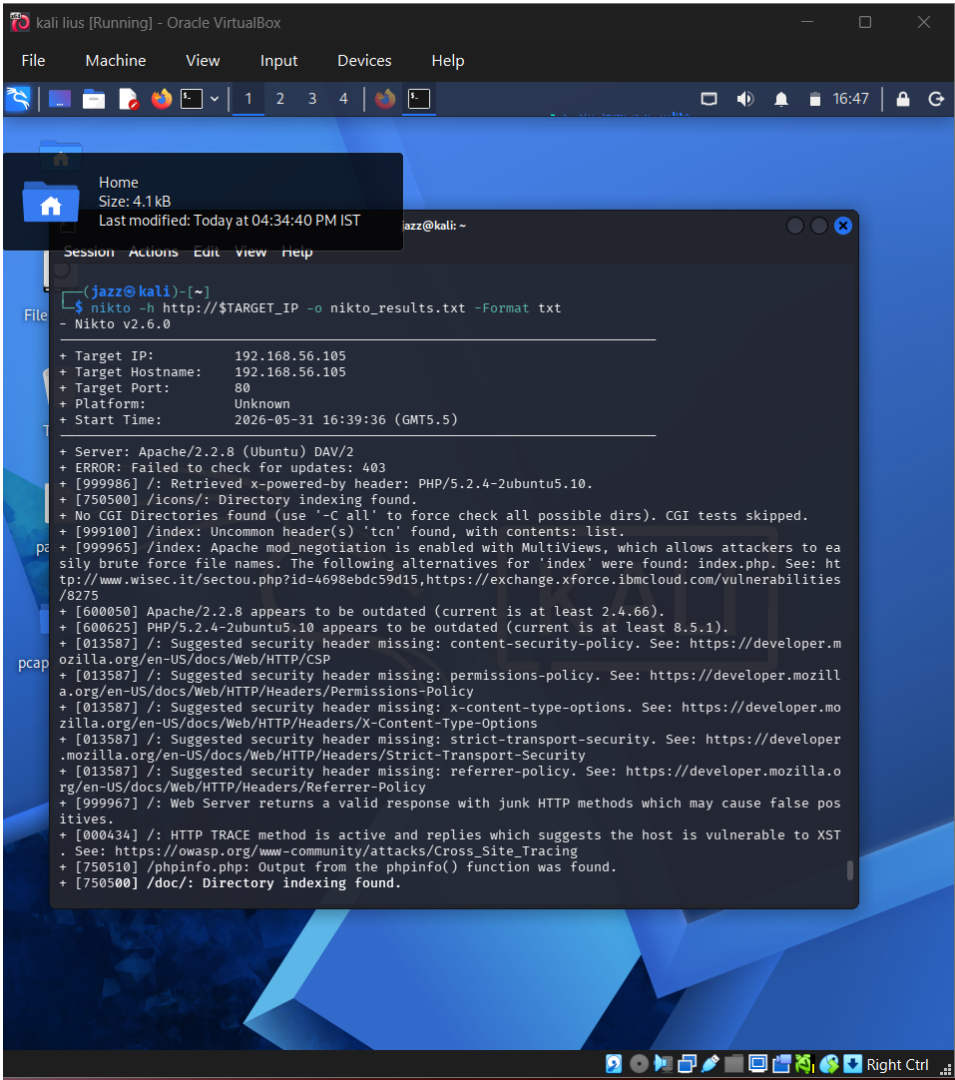


Figure 1 - Actual screenshot evidence: 07-nikto-scan-findings.png

What this screenshot proves

The screenshot shows Nikto reporting outdated Apache/PHP indicators, missing security headers, TRACE method evidence, phpinfo exposure, and directory indexing.

2. Evidence Context

Area	Value
Testing Phase	Vulnerability Scanning
Tool / Component	Nikto
Objective	Identify common web server misconfigurations, missing headers, and default/exposed files.
Result Type	Vulnerability scan output

3. Command / Workflow Used

```
nikto -h http://<TARGET_IP> -o nikto_results.txt -Format txt
```

The commands or workflow above represent the evidence-producing action. Placeholders such as , , or should be used in public documentation instead of live secrets or private infrastructure details.

4. Professional Interpretation

The screenshot shows Nikto reporting outdated Apache/PHP indicators, missing security headers, TRACE method evidence, phinfo exposure, and directory indexing.

This evidence should be treated as a supporting artifact, not as a standalone finding by itself. In a professional report, the screenshot supports a specific testing phase, validates an observation, and strengthens reproducibility when paired with methodology and remediation guidance.

5. Security Risk / Why It Matters

Web server misconfigurations can disclose information, weaken browser protections, or expose unnecessary attack surface.

For this portfolio project, the risk is described in a real-world context while clearly noting that the target was an authorized DVWA/local lab environment. This avoids exaggerating lab results as production impact.

6. Recommended Remediation / Defensive Control

Patch web stack components, remove phinfo, disable TRACE, add security headers, and disable directory indexing.

7. GitHub Redaction Requirements

Target IP, hostnames, server banners if not intended for public sharing, and internal paths.

Before pushing to GitHub, confirm that screenshots do not expose cookies, session IDs, credentials, hashes, cracked passwords, private IPs, internal file paths, or any secret values. If the screenshot already contains sensitive information, blur or crop it before upload.

8. GitHub README Link Snippet

```
[Open Evidence PDF](./reports/evidence-file-documentation-with-screenshots/08_07-nikto-scan-findings_evidence_documentation.pdf)
```

Legal and Ethical Note

This evidence documents authorized testing against an intentionally vulnerable local lab target. The techniques described must not be used against public or third-party systems without explicit permission.